

Evaluation empirique des modèles

Contents

4.1	Etat de l'art des datasets	2
4.1.1	Analyse des datasets 5G	2
4.1.2	Limites dans l'évaluation de la qualité des données	3
4.2	Génération d'un dataset	6
4.2.1	Traffic bénin	6
4.2.2	Traffic anormale	9
4.2.3	Méthodologie de génération	12
4.2.4	Environnement et implémentation	15
4.3	Evaluation des caractéristiques du dataset	15
4.3.1	Caractérisation sémantique	16
4.3.2	Caractérisation séquentielle	17
4.3.3	Caractérisation topologique	18
4.3.4	Synthèse	19
4.4	Expérimentation et résultats	19
4.4.1	Approche supervisée	20
4.4.2	Comparaison des méthodes de NLP	20
4.4.3	Approche non-supervisée	20
4.5	Représentation interprétable de détection	20
4.6	Conclusion	20

Les données constituent un élément central des approches d'apprentissage automatique. Pourtant, dans l'état de l'art appliqué à la 5G, aucun dataset ne semble aujourd'hui s'imposer comme référence commune. La majorité des travaux reposent sur des datasets construits localement par chaque équipe de recherche, souvent selon des méthodologies différentes et insuffisamment documentées. Cette absence de standardisation rend difficile la comparaison objective des modèles proposés dans la littérature. Dans ce contexte, la création d'un dataset de référence apparaît comme une opportunité importante pour la communauté scientifique. Toutefois, cette démarche soulève plusieurs questions fondamentales autour de la définition de la qualité d'un dataset, un sujet qui demeure aujourd'hui au cœur

des discussions de la communauté plus large de l'intelligence artificielle. Nous proposons donc, dans cette thèse, la conception d'un dataset dédié, en portant une attention particulière à la reproductibilité de son processus de génération ainsi qu'à l'évaluation des données produites.

Au moment de l'écriture de cette thèse, la recherche en apprentissage automatique fait face à une problématique croissante de reproductibilité des résultats. Dans de nombreux travaux, l'obtention de performances élevées sur des métriques de détection ou de classification constitue un critère déterminant pour la publication scientifique. En pratique, l'absence de scores compétitifs tend à éclipser les contributions méthodologiques pourtant pertinentes. Cette pression conduit à la multiplication de travaux présentant des résultats difficilement reproductibles ou insuffisamment documentés. Il devient alors complexe de déterminer si les performances observées traduisent réellement une bonne capacité de généralisation du modèle ou si elles résultent d'un surapprentissage sur des sous-ensembles de données peu représentatifs. Dans cette thèse, une attention particulière sera donc portée à la limitation des biais expérimentaux lors de la comparaison des modèles.

4.1 Etat de l'art des datasets

Dans cette section, nous commencerons par étudier les datasets existants ainsi que leurs limites, avant de présenter les principales recommandations et considérations méthodologiques relatives à la génération de datasets dans le domaine de l'apprentissage automatique.

4.1.1 Analyse des datasets 5G

Pour des raisons de confidentialité, les grands opérateurs de télécommunication partagent rarement les données issues de leurs réseaux. En l'absence d'accès à du trafic 5G réel, la principale solution pour les travaux de recherche consiste à s'appuyer sur des données synthétiques, générées à partir d'implémentations open-source de réseaux 5G. Bien qu'elles soient synthétiques, les données générées sur ces implémentations ne sont pas pour autant irréalistes. En effet, la 5G est en partie conçue pour des réseaux privés mobiles (MPN) et destiné aux entreprises souhaitant déployer des infrastructures dédiées, notamment pour garantir une faible latence ou protéger des données sensibles. Dans ces situations, il est souvent excessif de redévelopper entièrement un cœur 5G, ce qui favorise l'adoption d'implémentations open-source telles. On observe également des cas d'acteurs industriels tels que Firecell [?], qui proposent des solutions prêtes à l'emploi intégrant des implémentations basées sur OAI[?]. Ainsi, la génération de dataset à partir d'implémentations open-source reflète des usages réels et apparaît comme une solution légitime.

À notre connaissance, seuls trois travaux se positionnent officiellement comme des datasets 5G publics dédiés à la détection d'anomalies. 5G-NIDD [?] considère principalement des attaques génériques au niveau réseau, sans prendre en compte

les spécificités des réseaux 5G. PFCP Intrusion Detection Dataset [?] propose un large éventail d’attaques ciblant le plan de gestion de session, mais ne détaille pas la génération du trafic légitime. Enfin, 5GAD [?] introduit plusieurs attaques visant les interfaces orientées services du CN, mais son trafic normal repose essentiellement sur des activités utilisateur telles que le streaming vidéo ou le téléchargement de fichiers. Ce trafic étant chiffré, il diffère fortement du trafic de contrôle utilisé pour les attaques.

En l’absence de dataset public satisfaisant, les travaux sur la détection d’anomalies doivent généralement produire leurs propres données d’entraînement, souvent privées ou insuffisamment documentées. GSAD [?] et ADSeq-5GCN [?] proposent plusieurs procédures normales, telles que l’enregistrement d’UE ou l’établissement de session des UE mais ne couvrent cependant qu’un nombre limité d’attaques. PROV5GC [?] enrichit cette diversité de trafic légitime avec les changements d’état des UE. Néanmoins, parmi les attaques qu’ils proposent, certaines concernent le slicing et le signalement SMS, pour lesquels il n’introduisent pas d’équivalents légitimes avec lesquels faire contraster leurs attaques. Enfin, 5GCGuard [?] est le seul travail à notre connaissance fournissant des outils permettant de reproduire la génération des données. Cependant, seule une version prétraitée de leur dataset généré est publiée, sans accès aux captures brutes originales.

Dataset	PCAP	Code	Procédures bénignes				
			Enregistrement d’UE	Gestion de Session	Changement d’Etat	Gestion de NF	Transmission par UPF
5GAD[?]	✓	✓					
PFCP IDD[?]	✓						
GSAD[?]			✓				
AdSeq[?]			✓	✓			
PROV5GC[?]			✓	✓	✓		
5GCGuard[?]		✓	✓	✓			
Notre solution	✓	✓	✓	✓	✓	✓	✓

Table 4.1: Comparaison de différents datasets 5G et de leurs caractéristiques.

Ainsi, le principal problème des travaux récents réside dans le manque important de ressources publiques ainsi que dans l’absence de cohérence entre les attaques à détecter et le trafic normal utilisé pour les contraster. Le tableau ?? présente une synthèse comparative des travaux de l’état de l’art proposant des datasets 5G ou générant leurs propres données pour la détection d’anomalies.

4.1.2 Limites dans l’évaluation de la qualité des données

Afin d’évaluer correctement les performances des modèles de détection, il est nécessaire de s’assurer en amont que les données utilisées sont fiables et représentatives. Le machine learning est utilisé depuis longtemps pour les NIDS, ce qui a conduit à la constitution de nombreux datasets. Cependant, plusieurs travaux ont déjà mis en évidence des lacunes importantes dans des datasets pourtant considérés comme des références. L’exemple le plus connu est CIC-IDS-2017

[?], qui fait souvent consensus pour des tâches de détection d'anomalies réseau. Néanmoins, des travaux ont mis en lumière des problèmes critiques dans son contenu, notamment des erreurs d'étiquetage ainsi que la duplication de paquets [?]. Cela montre que la problématique est loin d'être triviale et qu'elle constitue encore un sujet d'actualité.

Dans leur travaux, Gharib et al. [?] ont proposé un ensemble de lignes directrices permettant d'évaluer les méthodologies de génération de datasets. Ces recommandations soulignent l'importance de la diversité des types de trafic, de l'anonymisation, ainsi que d'une documentation rigoureuse garantissant la reproductibilité. De leur côté, Flood et al. [?] apportent des éléments complémentaires en mettant en évidence des biais concrets présents dans des datasets largement utilisés. Ils montrent que ces biais permettent la détection d'anomalies même à l'aide de modèles extrêmement simples, ce qui remet en question la validité des résultats d'évaluation obtenus sur de telles données. Bien que ces travaux fournissent des recommandations utiles, ils s'appliquent principalement à des systèmes NIDS basés sur l'analyse de flux, plutôt que sur des paquets individuels.

Par conséquent, certaines de ces lignes directrices ne sont pas directement transposables et doivent être réinterprétées dans notre contexte. En compilant les recommandations issues de l'état de l'art et en les adaptant à notre problématique, nous identifions les objectifs suivants comme essentiels à la constitution d'un datasets 5G de qualité.

4.1.2.1 Exhaustivité des surfaces d'attaques

La littérature recense un large éventail d'attaques ciblant les réseaux mobiles et les infrastructures 5G. Cependant, la plupart des travaux présentant ces attaques se concentrent généralement sur un sous ensemble très restreint de ces entités et de leurs interactions. Un dataset de qualité doit donc être aussi exhaustif que possible, aussi bien du point de vue des attaques proposées que du trafic bénin associé.

Dans notre cas, le datasets mis en place couvre les appels d'API entre NF, la gestion de session ainsi que l'encapsulation des paquets.

4.1.2.2 Trafic légitime de nature adaptée

La détection d'anomalies nécessite de disposer d'exemples représentatifs de trafic légitime servant de référence face aux attaques. Pourtant, peu de travaux proposent un trafic bénin réellement comparable aux attaques qu'ils cherchent à détecter. Pour chaque attaque incluse dans le datasets, il est donc essentiel d'identifier les messages légitimes pouvant servir de référence lors de la détection.

Dans notre approche, chaque attaque intégrée au datasets est associée à au moins un type de message bénin auquel elle peut être comparée. Les résultats sont présentés dans la Table ??.

4.1.2.3 Caractérisation des attaques proposées

Lorsqu’un datasets intègre des attaques, il est essentiel d’identifier précisément les caractéristiques qui les distinguent du trafic bénin. Dans les sections précédentes, nous avons montré que les attaques pouvaient être catégorisées selon trois dimensions : sémantique, temporelle et topologique. Afin d’éviter l’introduction de biais, il est nécessaire de classifier chaque attaque selon ces dimensions et de vérifier qu’elle ne puisse être détectée qu’à travers l’analyse de la ou des dimensions qui la caractérisent.

Ainsi, pour chaque attaque incluse dans notre datasets, nous définissons explicitement les dimensions sur lesquelles elle doit être détectée. Ces correspondances sont détaillées dans la Table ??.

4.1.2.4 Définition du périmètre d’utilisation

Les biais peuvent apparaître très facilement dans un dataset et introduire des corrélations artificielles facilitant excessivement la détection. Par exemple, la prise en compte des adresses MAC par un utilisateur pourrait permettre de discriminer très facilement un attaquant. Afin de limiter ces biais autant que possible, il est important de distinguer clairement les surfaces constituant le véritable objectif du dataset de celles qui ne doivent pas être prises en compte lors de l’analyse.

Notre datasets est donc conçu pour être utilisé au niveau paquet sur les protocoles correspondant aux surfaces considérées, à savoir GTP, PFCP et HTTP/2. Tout autre protocole doit être exclu des analyses afin d’éviter l’introduction de biais non souhaités. La seule exception concerne la couche IP, pour laquelle les adresses source et destination doivent être conservées et utilisées comme identifiants des NF afin de permettre la détection des attaques basées sur les interactions.

Un autre point important de notre dataset est l’absence de contrainte de temps réel, cet aspect n’ayant pas d’impact significatif sur les attaques considérées. Ainsi, l’utilisation de notre dataset suppose de prendre uniquement en compte de l’ordre d’arrivée des paquets, et d’ignorer leurs horodatages exacts.

4.1.2.5 Caractéristiques fortement dépendantes

Une caractéristique fortement dépendante correspond à une propriété inattendue sur laquelle un modèle peut surapprendre durant l’entraînement. La définition du périmètre d’utilisation réduit déjà significativement le nombre de caractéristiques fortement dépendantes susceptibles d’apparaître. Toutefois, de telles caractéristiques peuvent encore émerger au sein des couches retenues. Nous définissons donc plusieurs critères visant à limiter leur apparition.

Pour toute attaque ne reposant pas sur une dimension sémantique, la payload doit être strictement identique à celui d’un paquet bénin. Dans le cas des attaques basées sur la répétition, il est nécessaire de randomiser l’ordre d’exécution des procédures et d’insérer du trafic bénin comme bruit de fond durant les attaques.

Enfin, pour les attaques basées sur les interactions, l'adresse IP de l'attaquant doit rester cohérente au sein d'une même instance d'attaque sans pour autant demeurer constante à l'échelle de l'ensemble du datasets.

4.2 Génération d'un dataset

Cette section décrit le dataset généré dans le cadre de nos travaux. Nous présentons dans un premier temps les différents types de messages bénins et malveillants retenus. Nous détaillons ensuite les choix méthodologiques mis en œuvre afin de garantir que les données produites respectent les critères de qualité précédemment définis. Enfin, nous décrivons le processus technique de génération du dataset, de manière à en assurer la reproductibilité.

4.2.1 Trafic bénin

Parmi le trafic de contrôle 5G, les échanges entre entités s'organisent sous forme de séquences de messages appelées procédures. Certaines procédures se limitent à quelques messages échangés entre deux acteurs, tandis que d'autres peuvent impliquer de nombreuses interactions entre plusieurs NF. En effet, lorsqu'une NF doit exécuter une action nécessitant des informations ou des ressources externes, elle peut être amenée à solliciter d'autres NFs, conduisant à des procédures complexes comportant parfois plusieurs dizaines de messages. La plupart sont déclenchées à la suite d'une action initiée par un utilisateur. Toutefois, certaines peuvent également être lancées par une fonction réseau du CN, soit en réaction à un événement particulier, soit de manière périodique.

Toutes les procédures ne présentent pas la même fréquence d'utilisation et le standard 5G en définit un très grand nombre, souvent décliné en plusieurs variantes. L'ensemble des procédures présentées dans cette section est décrit dans la spécification 3GPP TS 23.502 [?]. En pratique, il est difficile de reproduire exhaustivement l'ensemble de ces comportements, d'autant plus que les implémentations open-source disponibles ne couvrent qu'une partie des fonctionnalités prévues par les spécifications. Nous nous concentrons donc sur un sous-ensemble de procédures sélectionnées en fonction de leur importance opérationnelle et de leur pertinence vis-à-vis des scénarios d'attaque considérés. L'objectif est de disposer d'un trafic légitime suffisamment diversifié tout en garantissant la présence de procédures pouvant être directement mises en contraste avec les attaques incluses dans le dataset.

4.2.1.1 Enregistrement des UEs

Les procédures d'enregistrement des UEs sont celles les plus couramment utilisées dans l'état de l'art pour générer du trafic légitime. Elles produisent une vingtaine de requêtes réparties entre le RAN et le CN. Ces procédures font intervenir plusieurs protocoles, notamment NGAP, NAS et HTTP/2, ainsi que différentes NF telles

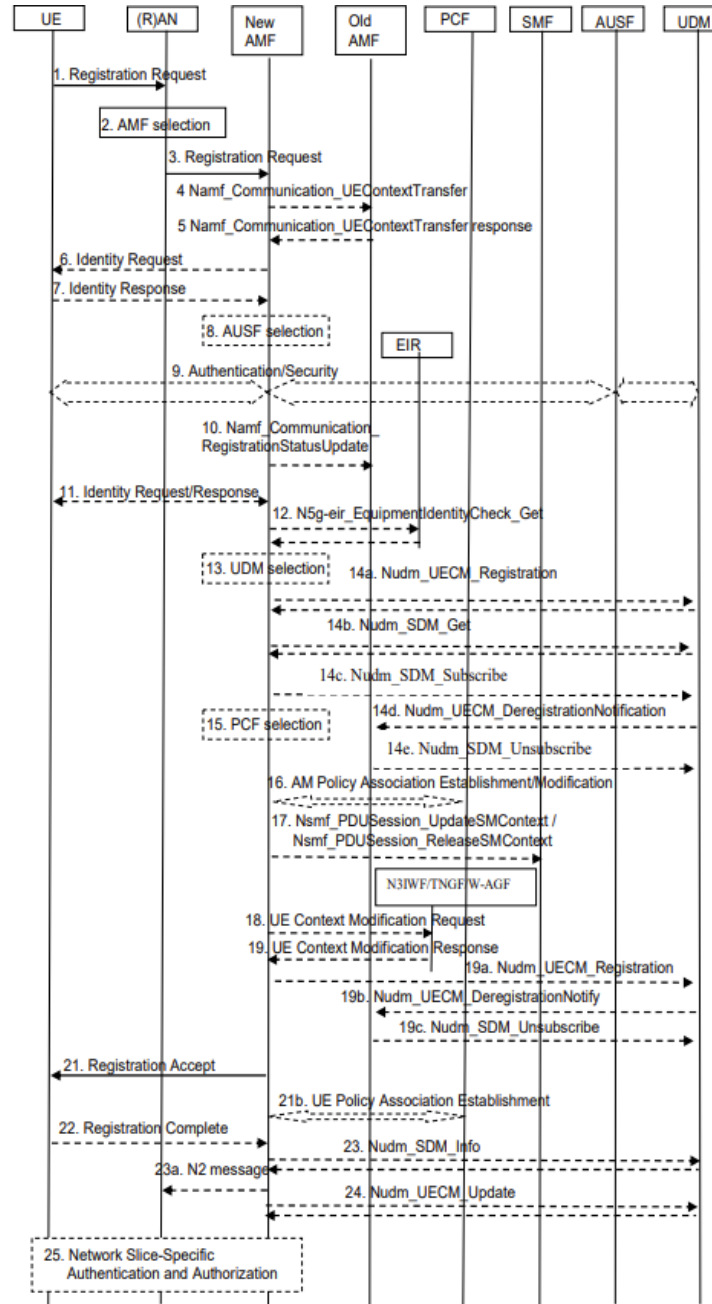


Figure 4.1: Procédure général d'enregistrement tel que proposé dans la TS 23.502 de 3GPP[?].

que l'AMF, le PCF, le SMF, l'AUSF et l'UDM. Dans le cadre de notre étude, leur principal intérêt réside dans la diversité des messages et des interactions qu'elles génèrent. La Figure ??, extraite de la spécification 3GPP, illustre une procédure complète d'enregistrement incluant l'ensemble des étapes optionnelles.

4.2.1.2 Changements d'état des UE

Dans la même logique que les procédures d'enregistrement, PROV5GC [?] propose un trafic légitime fondé sur les transitions d'état des UEs. Lorsqu'un UE demeure inactif pendant une certaine durée, une procédure de *Libération de contexte* est automatiquement déclenchée. Celle-ci génère une séquence de messages entre le RAN et le CN visant à modifier l'état de l'UE du point de vue du CN et ainsi économiser des ressources précédemment allouées. Dans notre cas, ces procédures sont déclenchées manuellement, en envoyant nous-mêmes le message de libération de contexte. Lorsqu'un UE inactif redevient actif, une procédure de *requête de service* est initiée afin de rétablir son état actif. Elle peut être déclenchée soit par la réception d'un message à destination d'un UE inactif, soit, à l'inverse, par l'envoi d'un message depuis ce dernier. Qu'il s'agisse de la libération de contexte ou de la reprise d'activité, ces procédures correspondent à des comportements courants dans les réseaux opérationnels et contribuent à accroître la diversité des messages présents dans le dataset.

4.2.1.3 Création et libération de session

Plusieurs attaques décrites dans l'état de l'art ciblent l'interface N4 reliant le SMF et l'UPF, responsable de la gestion des sessions. Sur cette interface, les échanges reposent sur le protocole PFCP. Parmi les procédures bénignes figurent notamment les procédures de création, de modification et de libération de session. Les procédures d'établissement et de modification de session sont incluses dans la procédure d'enregistrement de l'UE. Toutefois, il est également possible de redémarrer des sessions actives alors que l'UE est déjà enregistré, ce qui permet de considérer cette opération comme une procédure à part entière.

Certaines attaques [?] ciblant spécifiquement les messages PFCP associés à la création ou à la suppression de sessions, il est indispensable d'inclure des exemples légitimes de ces mêmes procédures dans le dataset afin de garantir une couverture réaliste des comportements du réseau.

4.2.1.4 Gestion des NF

Nous proposons également d'enrichir le trafic légitime disponible dans l'état de l'art par l'ajout de procédures jusqu'alors absentes mais pourtant nécessaires à la détection de certaines attaques. Il s'agit ici de la gestion des NF, à travers la simulation de leur ajout et de leur suppression au sein du CN. Ces opérations se limitent généralement à une unique requête d'API et surviennent naturellement lors du démarrage ou de l'arrêt du réseau. Toutefois, l'architecture du CN 5G étant conçue pour s'adapter dynamiquement aux variations de charge, nous simulons également ces opérations en cours d'exécution tout en garantissant la continuité du service. La manipulation de l'architecture du CN étant exploitée par certaines attaques [?], la présence de trafic légitime associé à ces opérations constitue également une référence nécessaire à leur détection.

4.2.1.5 Transfert de données par l'UPF

Enfin, nous introduisons une seconde procédure absente des travaux de l'état de l'art en générant du trafic utilisateur entre l'UE et le RAN. Le contenu transporté dans le plan utilisateur n'est pas spécifique à la 5G et se situe donc en dehors du périmètre de cette étude. En revanche, son acheminement nécessite l'encapsulation des paquets entre le gNB et l'UPF. Cette encapsulation repose sur le protocole GTP, qui constitue une cible fréquente des attaques décrites dans la littérature [?, ?]. L'inclusion de trafic utilisateur permet ainsi de générer des exemples légitimes d'utilisation de GTP, indispensables à la détection et à l'évaluation des attaques ciblant ce protocole.

Attaque	Source	Surface	Bénins comparables	Dimensions
Scan applicatif des NFs	5GAD[?]	CN	Découverte de NF	Sequentiel / Topologique
Fuzzing d'API	Originale	CN	Tout appel d'API	Sequentiel / Sémantique
Man-in-the-Middle dans le CN	Originale	CN	(Dé)enregistrement de NF	Sequentiel / Topologique
Inondation d'établissement de session	Amponis et al.[?]	SM	Création de session	Sequentiel
Inondation de libération de session	Amponis et al.[?]	SM	Libération de session	Sequentiel
DoS des sessions par modification	Amponis et al.[?]	SM	Modification de session	Sequentiel / Sémantique
Fuzzing du SEID	Originale	SM	Modification de session	Sequentiel
PFCP dans GTP-U	Park et al.[?]	UP	Tout message GTP-U	Sémantique
Usurpation de trafic montant	Trend Micro[?]	UP	Tout message GTP-U	Topologique

Note : CN = coeur de réseau; SM = gestion de session ; UP = plan utilisateur

Table 4.2: Liste des attaques présentes dans le dataset ainsi que leurs caractéristiques

4.2.2 Traffic anormale

La littérature recense un large éventail d'attaques ciblant les réseaux mobiles et les infrastructures 5G. Comme évoqué dans la section précédente, certaines de ces attaques exploitent des vulnérabilités spécifiques à des implémentations particulières et ne sont pas nécessairement réalistes dans le cas d'une entreprise disposant d'une implémentation robuste et conforme aux spécifications. Néanmoins, le réel enjeu ici est plutôt que les attaques restent distinguables du trafic normal selon des critères bien définis. Ainsi, en apprenant à détecter des anomalies sur une ou plusieurs des trois dimensions définies précédemment, un modèle peut ensuite être rendu utilisable dans un cadre opérationnel plus réaliste via un entraînement complémentaire sur des données réelles. Par ailleurs, étant donné que certaines implémentations open source sont utilisées dans des réseaux 5G privés, il est également possible que des vulnérabilités similaires et des attaques de ce type existent en pratique. Pour chaque attaque, nous avons identifié de manière explicite dans la Table ?? ces dimensions, ainsi que les surfaces d'attaque concernées et les procédures bénignes permettant une comparaison pertinente.

4.2.2.1 Scan applicatif des NFs

Dans les réseaux 5G, les NFs peuvent être instanciées et supprimées dynamiquement. Le NRF maintient un registre des instances actives ainsi que des métadonnées décrivant leurs capacités. Lorsqu'une NF nécessite un service particulier, elle interroge le NRF afin d'identifier les fournisseurs disponibles. 5GAD [?] souligne que, en l'absence de mécanismes d'authentification adéquats, ces requêtes de découverte peuvent être détournées par un attaquant afin de cartographier l'ensemble du CN. Nous implémentons ce scénario en générant une séquence de requêtes de découverte, chacune ciblant aléatoirement un type de NF différent. Ces messages, pris individuellement, sont entièrement bénins. Toutefois, c'est leur enchaînement ainsi que leur origine commune qui peuvent constituer un comportement anormal.

4.2.2.2 Fuzzing d'API

Les réseaux 5G étant conformes aux spécifications 3GPP, les schémas d'API sont publiquement accessibles. Un attaquant peut ainsi disposer d'une connaissance complète des requêtes possibles ainsi que des formats de paramètres d'entrée attendus. Cette accessibilité est renforcée par des travaux récents [?] ayant automatisé l'extraction de ces spécifications et leur mise à disposition dans des formats facilement exploitables. Dans ce contexte, un attaquant peut automatiquement générer des requêtes syntaxiquement valides mais contenant des paramètres falsifiés, susceptibles de provoquer des comportements anormaux selon l'implémentation du parser d'API. Dans notre code, nous sélectionnons aléatoirement des services au sein de plusieurs NFs et faisons varier systématiquement les paramètres associés. Ces messages peuvent être détectés soit individuellement via l'analyse de valeurs incohérentes, soit de manière séquentielle via l'identification de séquences anormales.

4.2.2.3 Man-in-the-Middle dans le CN

En l'absence de mécanismes d'authentification suffisants, un attaquant ayant accès au cœur de réseau peut enregistrer des NFs malveillantes de tout type. Lorsqu'une fonction malveillante se déclare comme fournisseur d'un service donné, elle apparaît alors dans les résultats de découverte au même titre que les instances légitimes. Dans le cas de free5GC, lorsqu'une fonction réseau doit sélectionner un fournisseur parmi plusieurs candidats, elle privilégie généralement celui ayant été enregistré le plus anciennement. Un attaquant peut exploiter ce comportement en supprimant puis en ré-enregistrant les NFs légitimes, de manière à faire apparaître sa fonction malveillante comme la plus ancienne. Cette manipulation lui permet de s'interposer dans les échanges et de rediriger le trafic sans interruption de service. On distingue alors deux phases dans ce scénario. La première correspond à la phase d'établissement, qui se caractérise par des séries de procédures anormales. La

seconde phase correspond à la redirection du trafic légitime, dans laquelle l'anomalie réside dans les interactions topologiques observées au sein du réseau.

4.2.2.4 Inondation d'établissement de session

Comme proposé par Amponis et al. [?], une attaque possible est de cibler l'UPF et de lui envoyer un grand nombre de requêtes de création de session. L'objectif est de saturer ses ressources de calcul et de mémoire, entraînant un ralentissement des autres requêtes légitimes. Dans notre implémentation, nous générons des séquences de requêtes de création de session avec des valeurs d'identifiants de sessions (SEID) et d'identifiants de tunnels (TEID) aléatoires. Dans ce contexte, les messages produits sont sémantiquement identiques aux messages légitimes et seule leur séquence permet de les distinguer du trafic normal.

4.2.2.5 Inondation de libération de session

Dans cette attaque, Amponis et al. [?] proposent de rompre les sessions établies entre l'UE et le réseau de données en envoyant des requêtes de libération. L'attaquant peut cibler un UE spécifique s'il connaît son SEID, ou bien effectuer une attaque par saturation en variant les identifiants afin de déconnecter un grand nombre d'UE. Dans notre implémentation, nous adoptons une stratégie similaire à celle de l'inondation d'établissement de session, en variant systématiquement les SEIDs. Cette attaque présente de fortes similarités avec la précédente et est donc également détectable principalement sur la dimension séquentielle.

4.2.2.6 DoS des sessions par modification

Amponis et al. [?] décrivent également des attaques reposant sur la modification des règles de transfert (FAR) afin de perturber discrètement l'accès au plan de données. Une première variante consiste à remplacer l'action de transfert (*forward*) par une action de suppression (*drop*), conduisant l'UPF à éliminer silencieusement les paquets associés à une session ciblée, sans qu'aucune notification ne soit transmise à l'UE. Une seconde variante repose sur la modification de la FAR afin de dupliquer les paquets au lieu de simplement les transférer. Cette duplication peut être utilisée à des fins d'écoute passive ou pour amplifier du DoS. Ces attaques peuvent être détectées à la fois par leur fréquence anormale et par leur contenu, qui comporte des champs ou des configurations inhabituels, absents des requêtes légitimes de modification de session.

4.2.2.7 Fuzzing de SEID

Les attaques de libération et de DoS de sessions supposent l'existence d'une session valide dont le SEID est connu. En l'absence de connaissance d'un SEID valide, un attaquant peut tenter d'exécuter son attaque en testant successivement différents SEID jusqu'à obtenir un résultat concluant. Toutefois, dans le cas des DoS

par modification, cette approche peut être détectée à la fois sur les dimensions sémantique et séquentielle. Dans le cas d'attaques par libération de session, dès qu'un SEID valide est identifié, la session associée est supprimée, ce qui empêche toute réutilisation ultérieure de cet identifiant. Afin de discrètement identifier des SEID actifs, un attaquant peut exploiter le comportement des requêtes de modification de session, qui produisent une réponse positive lorsque le SEID existe et une réponse négative dans le cas contraire, même lorsque la requête n'entraîne aucune modification effective de l'état de la session (par exemple lorsque les paramètres demandés correspondent déjà à l'état courant). L'attaquant peut ainsi envoyer un grand nombre de requêtes de modification bénignes, sémantiquement correctes et sans effet, et observer les réponses obtenues. De cette manière, il est possible d'extraire une liste de SEID actifs tout en restant détectable uniquement via la dimension séquentielle.

4.2.2.8 PFCP dans GTP-U

Park et al. [?] présentent une vulnérabilité liée au processus de décapsulation de l'UPF. Lorsqu'un utilisateur envoie des données vers le réseau de données, celles-ci sont encapsulées dans un paquet GTP-U traversant l'UPF. Celui-ci décapsule le paquet et le redirige vers sa destination. Toutefois, certaines implémentations, telles que free5GC, ne vérifient pas la nature du protocole encapsulé et le traitent de manière transparente. Il devient alors possible d'injecter des messages PFCP dans un tunnel GTP-U. Dans notre cas, nous encapsulons un unique message de suppression de session PFCP dans un paquet GTP-U. Ce type de d'encapsulation n'est pas prévu par les spécifications, ce qui rend l'anomalie détectable sur la dimension sémantique.

4.2.2.9 Usurpation d'utilisateur

Trend Micro met en évidence une vulnérabilité de type réflexion de paquets dans le protocole GTP-U [?]. En l'absence de validation appropriée, un attaquant ayant accès à l'UPF peut envoyer depuis ce dernier un paquet GTP-U encapsulant un paquet IP falsifié contenant celle d'un UE légitime. Une fois désencapsulé, ce paquet est relayé vers l'Internet, permettant à l'attaquant d'usurper l'identité de l'UE. Celui-ci peut alors émettre des requêtes en se faisant passer pour l'utilisateur légitime et réaliser des actions en son nom. Par exemple, un comportement malveillant répété pourrait conduire certains services à bloquer l'adresse IP associée à cet utilisateur, sans que celui-ci en soit responsable. Son identification repose principalement sur l'analyse de la dimension topologique, en mettant en évidence des incohérences dans les interactions observées entre les différentes entités du réseau.

4.2.3 Méthodologie de génération

Afin de limiter les biais, nous présentons dans cette section les choix méthodologiques ainsi que les mesures mises en œuvre afin de garantir la qualité, la représentativité et la cohérence du dataset généré.

4.2.3.1 Longueur des attaques par répétition

Parmi les attaques considérées, celles reposant sur la dimension séquentielle, telles que les attaques d'inondation, consistent en l'émission d'un même message répété un certain nombre de fois. Nous fixons ce nombre de répétitions à 100 messages. Cette valeur nous semble suffisamment élevée pour produire un comportement anormal clairement identifiable. En effet, dans un réseau 5G en fonctionnement normal, il est rare d'observer plus de trois ou quatre messages sémantiquement identiques et émis successivement. Une séquence de 100 répétitions permet donc de reproduire un comportement anormal sans pour autant surcharger inutilement le dataset. Par ailleurs, ces traces étant utilisées uniquement à des fins d'évaluation, le maintien d'un nombre fixe de répétitions ne devrait pas introduire de biais significatif.

4.2.3.2 Préservation du contexte temporel

La plupart des datasets 5G existants séparent le trafic bénin et le trafic malveillant en les plaçant dans des intervalles temporels distincts. Cette approche est explicitement critiquée par Flood et al. [?], car elle empêche la conservation d'un contexte séquentiel pertinent et favorise l'apparition d'un sur-apprentissage basé sur les périodes plutôt que sur le contenu des échanges. Afin de reproduire des séquences plus réalistes, nous adoptons une approche similaire à celle proposée par 5GCGuard [?], consistant à entrelacer le trafic malveillant avec une activité bénigne de fond pendant l'exécution des attaques. Pour ce faire, nous exécutons en parallèle un script générant des procédures bénignes et un autre dédié aux procédures malveillantes. Dans chaque cas, les procédures sont sélectionnées aléatoirement parmi l'ensemble de celles que nous avons implémentées.

4.2.3.3 Préservation du contexte d'identité

Une autre approche couramment utilisée pour distinguer le trafic bénin du trafic malveillant consiste à s'appuyer sur des identités, telles que l'adresse IP. Cette pratique est fréquente dans les datasets d'IDS, les adresses étant généralement anonymisées a posteriori afin de préserver la confidentialité des utilisateurs. Dans notre cas, le dataset étant entièrement synthétique, il n'est pas soumis à ces contraintes. Nous conservons donc les adresses IP, qui sont essentielles pour la détection des anomalies de nature topologique.

Toutefois, l'utilisation d'une adresse IP fixe pour l'attaquant peut conduire un modèle à sur-apprendre cette caractéristique et à identifier un attaquant uniquement à partir de son adresse. Afin d'éviter ce biais, nous faisons en sorte que l'adresse

source associée aux messages d'attaque corresponde à celle d'une NF légitime choisie aléatoirement au sein du CN. Cette configuration peut par exemple simuler la compromission d'une fonction réseau légitime. Afin de conserver un contexte topologique cohérent, nous garantissons toutefois que l'ensemble des messages appartenant à une même procédure d'attaque partagent la même adresse de fonction réseau d'origine.

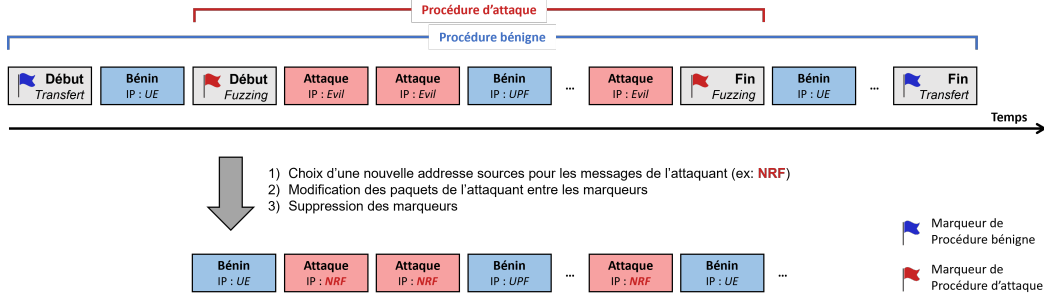


Figure 4.2: Processus de labellisation préservant les contextes temporels et topologiques grâce à l'utilisation de marqueurs.

4.2.3.4 Labelisation du dataset

Afin d'attribuer une adresse IP cohérente à l'ensemble des paquets appartenant à une même procédure, il est nécessaire d'identifier, pour chaque paquet, à quelle procédure il appartient. Dans cette optique, les attaques sont initialement générées à partir d'une même machine source. Au lancement de chaque procédure, qu'elle soit bénigne ou malveillante, des marqueurs sont injectés sous la forme de paquets UDP temporaires contenant le nom de la procédure.

Ces marqueurs permettent de délimiter automatiquement les frontières temporelles de chaque procédure et de restreindre la modification des adresses source aux seuls paquets situés entre ces bornes. Il est ainsi possible de modifier a posteriori l'ensemble des adresses IP comprises entre deux marqueurs de manière cohérente. Par ailleurs, cette approche permet de générer, en parallèle, une table de correspondance reliant les identifiants des paquets aux noms des procédures associées. Ce processus est illustré sur la figure ??.

4.2.4 Environnement et implémentation

Les implémentations commerciales de la 5G n'étant pas librement accessibles, nous nous appuyons sur des projets open source afin de simuler des déploiements réalistes. Plus précisément, nous utilisons *free5GC* [?] pour émuler le CN, ainsi que *UERANSIM* [?] pour simuler les UEs et les gNBs du réseau d'accès. Ces outils ont été retenus en raison de leur large adoption au sein de la communauté scientifique et de leur utilisation fréquente dans les travaux de génération de données 5G.

Bénin			Attaque		
Nom	Procédures	Paquets	Nom	Procédures	Paquets
Enregistrement d'UE	591	467,638	Fuzzing d'API	107	33,308
Redémarrage de session	562	379,181	MiTM dans le CN	123	22,587
Trafic utilisateur	317	159,228	Fuzzing de SEID	116	23,858
Libération de contexte	288	67,124	Inondation d'établissement	113	23,949
Réveil par envoi	137	55,599	Inondation de libération	98	20,446
Deregister UE	276	50,279	Scan applicatif	81	4,997
Réveil par reception	279	21,884	Modification : Duplication	119	345
Ajout de NF	261	18,232	Modification : Suppression	100	292
Suppression de NF	253	16,336	Usurpation d'utilisateur	102	102
			PFCP dans GTP-U	101	101
Total	2 265	1 235 501	Total	1 060	129 985

Table 4.3: Nombre de procédures et de paquets pour les scénarios bénins et d'attaque, classés par volume de paquets

Bien que *free5GC* et *UERANSIM* puissent être exécutés directement sous forme de binaires, nous avons choisi de les déployer via Docker, au moyen du projet *free5gc-compose* [?]. L'utilisation de la conteneurisation permet de disposer d'environnements préconfigurés pour l'ensemble des composants, ce qui simplifie le déploiement et améliore la reproductibilité des expériences.

Nous avons également apporté plusieurs modifications à cette architecture basée sur Docker. Tout d'abord, les adresses IP des fonctions réseau ont été fixées, la configuration par défaut reposant sur une attribution dynamique à chaque déploiement. De plus, un nouveau conteneur nommé *NF_EVIL* a été ajouté afin d'exécuter les scénarios d'attaque. Par ailleurs, nous avons modifié le Dockerfile de *UERANSIM* afin d'utiliser notre propre fork, la version originale présentant une défaillance affectant le mécanisme de libération du contexte UE, la rendant inutilisable pour nos expérimentations. La version corrigée est disponible dans notre dépôt GitHub [?].

Le dataset d'apprentissage est constitué exclusivement de trafic bénin, généré sur une période de 15 heures, correspondant à environ 10 000 procédures individuelles. Le dataset d'évaluation, quant à lui, a été produit en exécutant simultanément du trafic bénin et des scénarios d'attaque pendant 4 heures. Les volumes de trafic générés sont résumés dans le tableau ??.

Les volumes de trafic associés aux attaques présentent une forte hétérogénéité. Celle-ci reflète la distinction entre les attaques fondées sur la répétition de messages, qui génèrent un trafic conséquent, et les attaques sémantiques, dont l'exécution repose généralement sur un nombre restreint de requêtes, voire sur une seule interaction.

4.3 Evaluation des caractéristiques du dataset

Nous avons présenté dans les sections précédentes les différents objectifs de qualité retenus pour la conception de notre dataset, ainsi que la méthodologie mise en œuvre pour les satisfaire. Les procédures bénignes associées à chaque attaque ont été présentées dans la Table ???. L'objectif de cette section est de vérifier que les attaques incluses dans le dataset ne peuvent être distinguées du trafic légitime associé qu'à travers les dimensions pour lesquelles elles ont été conçues.

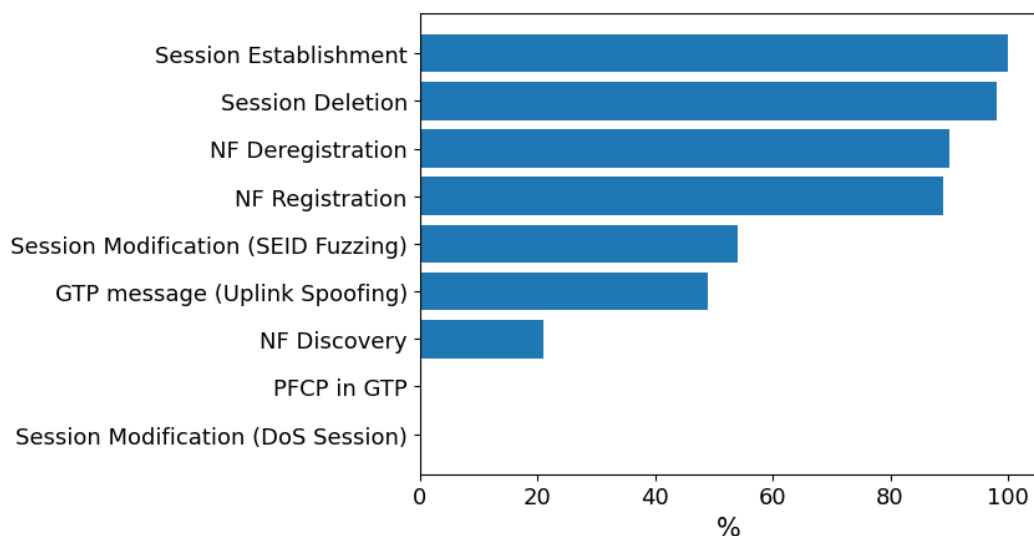


Figure 4.3: Proportion de messages bénins sémantiquement identiques à des messages d'attaque de même nature.

4.3.1 Caractérisation sémantique

Afin d'évaluer les attaques sur la dimension sémantique, nous avons calculé, pour chacune d'elles, la distance de Jaccard entre leurs paramètres et ceux des messages bénins correspondants. Cette métrique permet de quantifier la similarité sémantique entre deux contenus de paquets. Une distance nulle signifie que les deux messages partagent exactement les mêmes champs protocolaires et sont donc sémantiquement identiques.

Cependant, il existe une grande diversité de messages bénins, qui diffèrent même sémantiquement entre eux. Ainsi, une attaque ne peut pas être identique à l'ensemble des messages bénins. Nous nous intéressons donc à la proportion de messages bénins présentant une distance nulle avec nos attaques. La Figure ?? illustre ce résultat. On y observe que seules les attaques sémantiques considérées, à savoir PFCP dans GTP ainsi que la modification de session, ne présentent aucun équivalent bénin strictement identique.

Pour les autres attaques, supposées non discriminables sur la seule dimension sémantique, on constate qu'au moins 20% des paquets bénins observés lors de

l'entraînement leur sont strictement identique. Ainsi, le modèle a nécessairement été exposé, lors de l'apprentissage sur le trafic légitime, à des messages structurellement identiques à ceux générés par ces attaques. Les variations observées entre les différentes proportions peuvent s'expliquer par la forte hétérogénéité des messages bénins. Plus les messages associés à une même procédure sont diversifiés, plus la probabilité d'observer des correspondances exactes diminue.

L'attaque de fuzzing d'API constitue un cas particulier et n'a pas été intégrée à cette analyse globale. En effet, elle génère des messages sémantiquement différents selon les endpoints sollicités, ce qui nécessite une analyse distincte de leurs caractéristiques. Par ailleurs, l'objectif du fuzzing étant d'émuler des requêtes sémantiquement correctes, une partie des requêtes produites correspond de fait à des requêtes légitimes. En calculant la distance de Jaccard pour chaque type d'appel d'API indépendamment, nous observons que 89% des messages générés par cette attaque ne possèdent aucun équivalent sémantiquement identique dans le trafic bénin. Les 11% restants correspondent à des requêtes fortement plausibles, dont la détection repose davantage sur leur contexte temporel que sur leur seule structure sémantique.

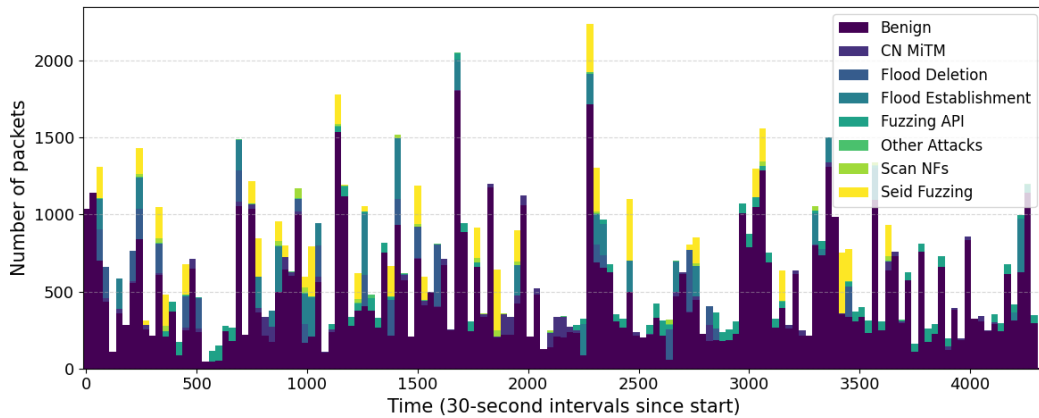


Figure 4.4: Distribution des messages issues de procédures d'attaques et bénignes en fonction du temps.

4.3.2 Caractérisation séquentielle

Nous avons vu dans les sections précédentes que nous cherchions à limiter les biais temporels en introduisant du bruit de fond durant les phases d'attaque et en randomisant l'ordre d'exécution des événements. La Figure ?? met en évidence que, lors de l'exécution d'une attaque, du trafic bénin est systématiquement présent en parallèle, ce qui empêche toute isolation temporelle simple de l'attaque. Cette figure illustre également les différences de longueurs de séquences selon les types d'attaques. Les attaques non fondées sur la répétition apparaissent en très faible quantité, car elles reposent généralement sur un nombre réduit de paquets.

Il existe néanmoins quelques cas particuliers qu'il convient de détailler ici. Bien que les attaques de type scan applicatif soient généralement détectables sur la dimension temporelle, elles génèrent un volume relativement faible sur les graphiques observés. Cela s'explique par le fait que, bien qu'elles reposent sur un principe de répétition, elles n'ont pas besoin de produire un grand nombre de requêtes pour être efficaces.

À l'inverse, l'attaque de type MiTM génère un nombre important de paquets bien qu'elle ne soit pas fondée sur la répétition. En effet, si sa phase d'initialisation nécessite un faible nombre de messages, l'ensemble des paquets relayés par la suite est systématiquement annoté comme anomalie. Le fait de considérer les paquets redirigés comme appartenant à la procédure MiTM conduit ainsi à une augmentation artificielle du volume de messages associés à cette attaque. Toutefois, comme il s'agit essentiellement d'une redirection de trafic légitime, les séquences restent structurellement similaires à du trafic bénin et ne peuvent être discriminées qu'en analysant les identités et la topologie des échanges. La longueur des séquences associées au MiTM est par ailleurs fortement variable, car elle dépend à la fois de la fonction usurpée et de l'intensité avec laquelle celle-ci est sollicitée par le trafic bénin durant la prise de contrôle.

Le dernier cas particulier concerne le fuzzing applicatif. Celui-ci constitue une attaque reposant sur la répétition, générant typiquement de l'ordre d'une centaine de messages par exécution. Cependant, la figure montre que ces messages présentent moins de pics temporels marqués que les autres attaques séquentielles et sont, au contraire, davantage dispersés dans le temps. Ce comportement s'explique par le fait que certaines exécutions de fuzzing peuvent être relativement longues et s'étendre sur plusieurs minutes, en fonction du temps de réponse des NF.

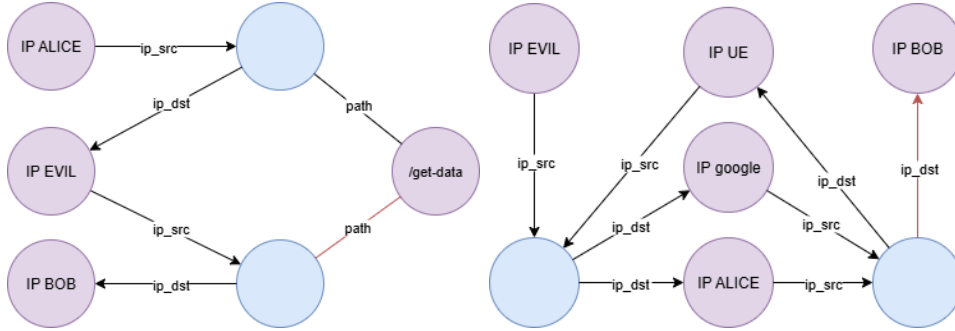


Figure 4.5: Schéma d'interactions : (a) MiTM dans le CN (b) Usurpation d'utilisateur.

4.3.3 Caractérisation topologique

La dernière dimension d'attaques que l'on veut vérifier est la dimension topologique. L'objectif ici est de vérifier que les motifs théoriques caractérisant ces attaques apparaissent effectivement dans le dataset. Ces motifs sont illustrés en Figure ??

et ne peuvent pas se produire dans un trafic normal d'un réseau respectant la spécification 3GPP. Afin de dénombrer ces occurrences, nous avons transformé les paquets du dataset en graphes, puis recherché dans ces graphes les motifs suivants.

Dans le cas du MiTM, nous avons identifié un motif de redirection durant sa phase opérationnelle, dans lequel le récepteur d'une requête API redirige la même requête vers un autre NF. Le nombre d'occurrences de ce motif dépend directement du volume de trafic bénin sollicitant le MiTM. Étant donné que ce trafic est généralement important, nous observons ainsi de l'ordre de 4500 occurrences de ce motif, ce qui dépasse largement le nombre d'exécutions distinctes de la procédure MiTM.

Pour l'attaque d'usurpation d'utilisateur, nous avons recherché une requête GTP-U dont l'adresse IP source dans l'en-tête IP externe diffère de l'adresse IP de destination de la réponse correspondante. Afin de garantir qu'il s'agit bien d'une réponse, nous vérifions également la cohérence des adresses IP internes. La recherche de ce motif ne permet d'identifier que 72 occurrences, soit 20 de moins que le nombre d'exécutions de la procédure de spoofing. Cet écart est attendu, dans la mesure où des pertes de paquets peuvent être observées lors des requêtes adressées au service web sollicité.

4.3.4 Synthèse

Nous avons vérifié dans cette section que, pour chacune des attaques de notre dataset, la discriminabilité n'est possible qu'au regard des dimensions que nous avons définies. Nous obtenons ainsi un dataset dans lequel le risque de biais a été autant que possible réduit et que nous pourrions utiliser pendant l'entraînement et l'évaluation de nos modèles, dont les expérimentations sont détaillées dans la section suivante.

4.4 Expérimentation et résultats

Nous souhaitons comparer expérimentalement plusieurs configurations et modèles afin de vérifier nos théories. Pour comparer de manière rigoureuse, il est essentiel de disposer d'un cadre expérimental unifié pour éviter des biais liés aux choix d'implémentation. Pour cette raison, nous nous appuyons sur DyGLib, la bibliothèque proposée par Yu et al. [?] et qui fournit un environnement unifié et bien établi regroupant plusieurs modèles de référence de l'état de l'art.

Comme présenté dans la section 3.4.5, notre problématique se distingue des scénarios classiquement considérés dans la littérature. Afin de mieux répondre à nos besoins, plusieurs adaptations ont été apportées à la bibliothèque. Ces modifications concernent notamment la prise en compte des informations temporelles associées aux événements ainsi que la gestion des parcours multi-sauts. Ces changements ont été implémentés sous la forme d'un fork de DyGLib, disponible à l'adresse indiquée dans [?].

L'utilisation de DyGLib nous permet ainsi non seulement de comparer les différents modèles dans un cadre homogène, mais également d'évaluer leurs performances dans plusieurs configurations d'apprentissage, notamment en mode supervisé et non supervisé. Nous étudierons également l'impact des différentes variantes de NLP présentées précédemment. Les résultats de ces expérimentations sont présentés dans les sections suivantes.

4.4.1 Approche supervisée

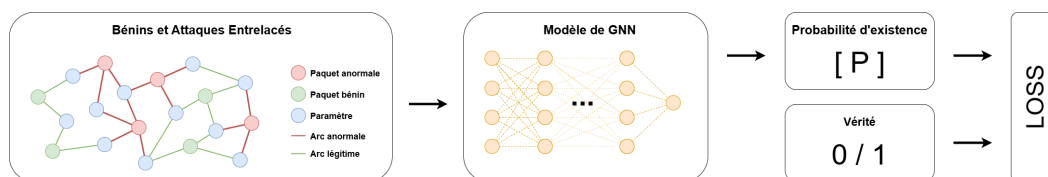


Figure 4.6:

La première approche qu'on considère c'est le supervisé. Comme on a vu dans la section 3.6, l'inconvénient de ce type d'apprentissage c'est qu'on a besoin de mettre des attaques dans le dataset d'entraînement et du coup on pourra détecter que des attaques connues ou des variantes proches. Néanmoins vu qu'on sait quel type de paramètre on veut détecter on peut en prendre qu'un sous ensemble et les encoder avec un one-hot encoder, ce qui réduit beaucoup la complexité et permet d'avoir de meilleurs résultats. De plus, détecter des anomalies connues n'est pas non plus sans intérêt et grâce à notre formalisme on peut le faire de manière très interpretable. Enfin, ce genre de modèle pourrait très bien être ré-entraîné au fur et à mesure de la détection de nouveaux pattern malveillant ou mise à jour du système

4.4.2 Comparaison des méthodes de NLP

4.4.3 Approche non-supervisée

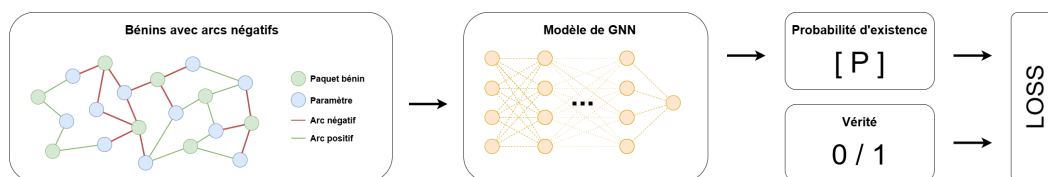


Figure 4.7:

4.5 Représentation interpretable de détection

4.6 Conclusion

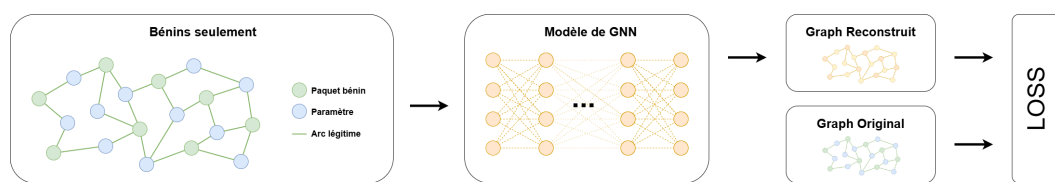


Figure 4.8: